

Informe de Investigación de Alerta SOC

1. Información General de la Alerta

Analista: Joaquín Picazo

ID del evento: 320

Fecha y hora: 22 de julio de 2025, 01:07 PM

Regla / Alerta: SOC342 - CVE-2025-53770 (SharePoint ToolShell Auth Bypass and RCE)

IP de origen: 107.191.58.76

IP de destino (SharePoint01): 172.16.20.17

Razón del desencadenamiento: Solicitud POST no autenticada y sospechosa dirigida a ToolPane.aspx, con un payload de gran tamaño y referer falsificado, indicativo de explotación de la vulnerabilidad CVE-2025-53770.

URL solicitada: /_layouts/15/ToolPane.aspx?DisplayMode=Edit&a=/ToolPane.aspx

Acción: Permitida

Severidad: Crítica

2. Resumen Ejecutivo

Se ha confirmado una brecha de seguridad crítica en el servidor SharePoint derivada de la explotación exitosa de la vulnerabilidad CVE-2025-53770. El atacante logró Ejecución Remota de Código (RCE), permitiendo la inyección de payloads maliciosos, la creación de un WebShell y el acceso a claves de cifrado del sistema. El activo afectado ha sido aislado de la red para prevenir la propagación del ataque y la exfiltración de información. El incidente es tratado como prioridad alta, con medidas de mitigación en curso y una investigación profunda para asegurar la recuperación del entorno.

3. Pasos de la Investigación

Se inició el proceso con la validación del evento, confirmando un intento de ataque dirigido a ToolPane.aspx mediante la explotación de la vulnerabilidad ToolShell CVE-2025-53770.

SEVERITY	DATE	RULE NAME	EVENTID	TYPE
Critical	Jul, 22, 2025, 01:07 PM	★ SOC342 - CVE-2025-53770 SharePoint ToolShell Auth Bypass and RCE	320	Web Attack
★ A critical zero-day vulnerability named ToolShell (CVE-2025-53770) has been discovered in on-premises SharePoint Server deployments.				
EventID :		320		
Event Time :		Jul, 22, 2025, 01:07 PM		
Rule :		SOC342 - CVE-2025-53770 SharePoint ToolShell Auth Bypass and RCE		
Level :		Security Analyst		
Hostname :		SharePoint01		
Source IP Address :		107.191.58.76		
Destination IP Address :		172.16.20.17		
HTTP Request Method :		POST		
Requested URL :		/_layouts/15/ToolPane.aspx?DisplayMode=Edit&a=/ToolPane.aspx		
User-Agent :		Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:120.0) Gecko/20100101 Firefox/120.0		
Referer :		/_layouts/SignOut.aspx		
Content-Length :		7699		
Alert Trigger Reason :		Suspicious unauthenticated POST request targeting ToolPane.aspx with large payload referer indicative of CVE-2025-53770 exploitation.		
Device Action :		Allowed		

Figura 1: Información alerta SOC

Se analizó la IP de origen 107.191.58.76, obteniendo datos de inteligencia de amenazas que corroboran múltiples reportes previos vinculados a actividades maliciosas.

IP Abuse Reports for 107.191.58.76:			
This IP address has been reported a total of 26 times from 26 distinct sources. 107.191.58.76 was first reported on July 19th 2025, and the most recent report was 10 months ago.			
Old Reports: The most recent abuse report for this IP address is from 10 months ago . It is possible that this IP is no longer involved in abusive activities.			
Reporter	IoA Timestamp (UTC)	Comment	Categories
✓ CyberSamurai	2025-07-21 13:56:11 (10 months ago)	Bad IP Reputation	Hacking
🚩 Tokolosh Hunters	2025-07-21 08:17:12 (10 months ago)	sharepoint rce ioc	Brute-Force
✓ Anonymous	2025-07-20 16:13:00 (10 months ago)	Observed exploiting MS SharePoint CVE-2025-53770 v ulnerability, according to Eye Security (https://r ... show more	Web App Attack
✓ Anonymous	2025-07-19 13:53:41 (10 months ago)	Unauthorized Repeated Recursive Lookups Domain: sl	DNS Poisoning
✓ anon333	2025-07-19 04:33:09 (10 months ago)	Hacker syslog review 1752899588	Hacking
✓ rtbh.com.tr	2025-07-19 04:07:45 (10 months ago)	list.rtbh.com.tr report: udp/53	Brute-Force

Figura 2: Inteligencia de amenazas de la IP origen 107.191.58.76.

Durante el examen de los registros, se identificó una petición POST anómala que empleaba un Referer falsificado con el objetivo de evadir los controles de seguridad perimetrales.

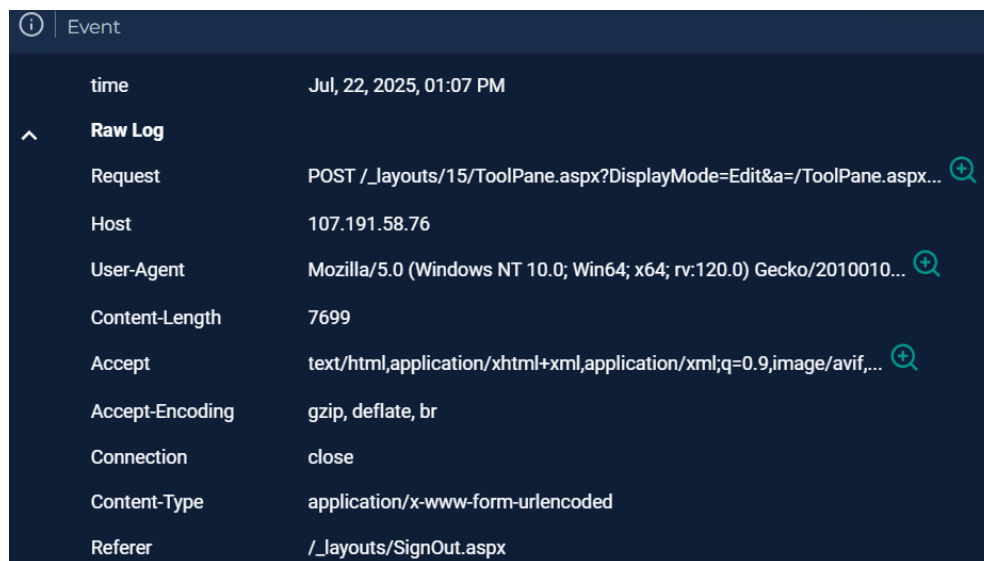


Figura 3: Registro de la petición POST anómala con Referer falsificado.

El historial de comandos del endpoint reveló la ejecución de diversas operaciones inusuales y altamente sospechosas.

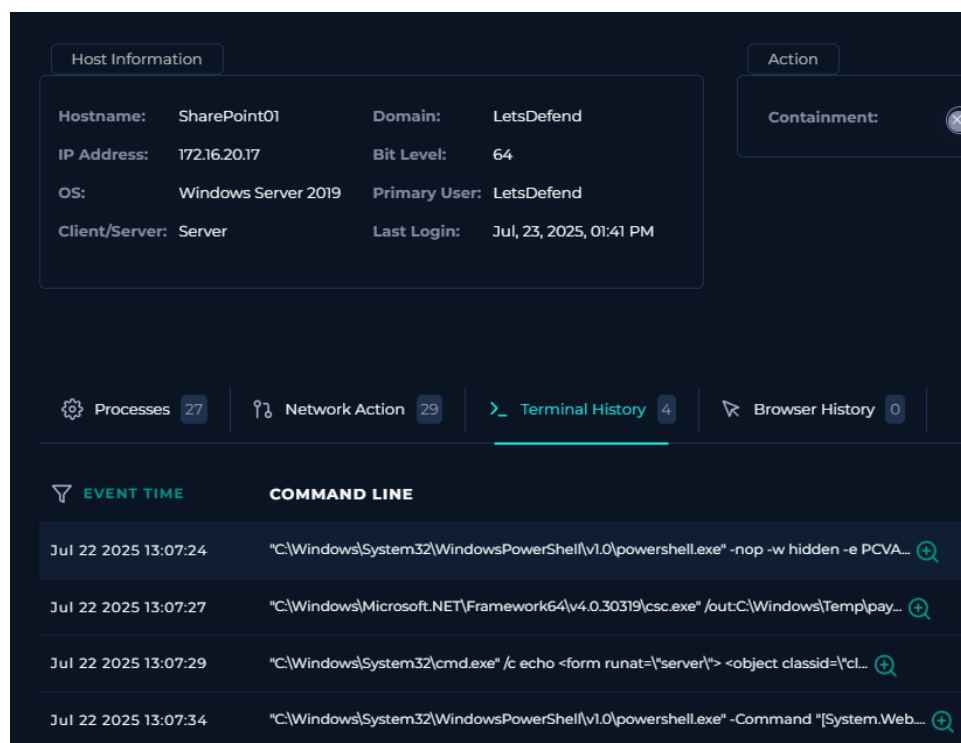


Figura 4: Historial de comandos en el endpoint.

Se detectó que varios de estos comandos estaban codificados en base64, una técnica empleada frecuentemente para eludir las políticas de seguridad de PowerShell.

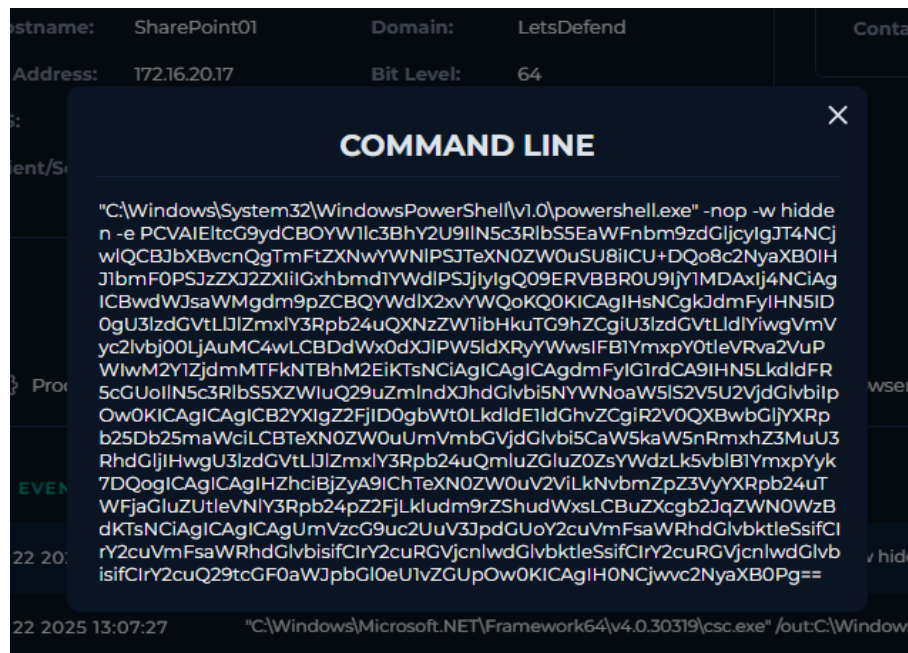


Figura 5: Detección de comandos codificados en Base64.

El análisis del código recuperado permitió identificar un payload malicioso en C# diseñado como WebShell, el cual utiliza técnicas de reflexión en ASP.NET para evadir restricciones y extraer claves criptográficas maestras como MachineKey, ValidationKey y DecryptionKey. Esta acción facilita al atacante la falsificación de sesiones, la suplantación de identidad y la obtención de ejecución remota de código persistente en el servidor.

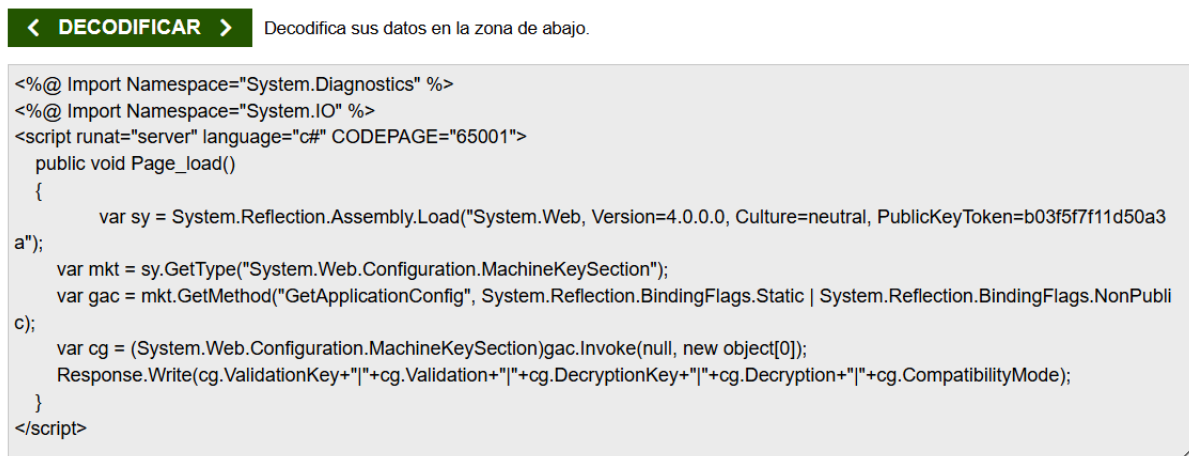


Figura 6: Análisis del payload WebShell en C#.

Se procedió a la revisión del hash de los procesos detectados en el equipo afectado.

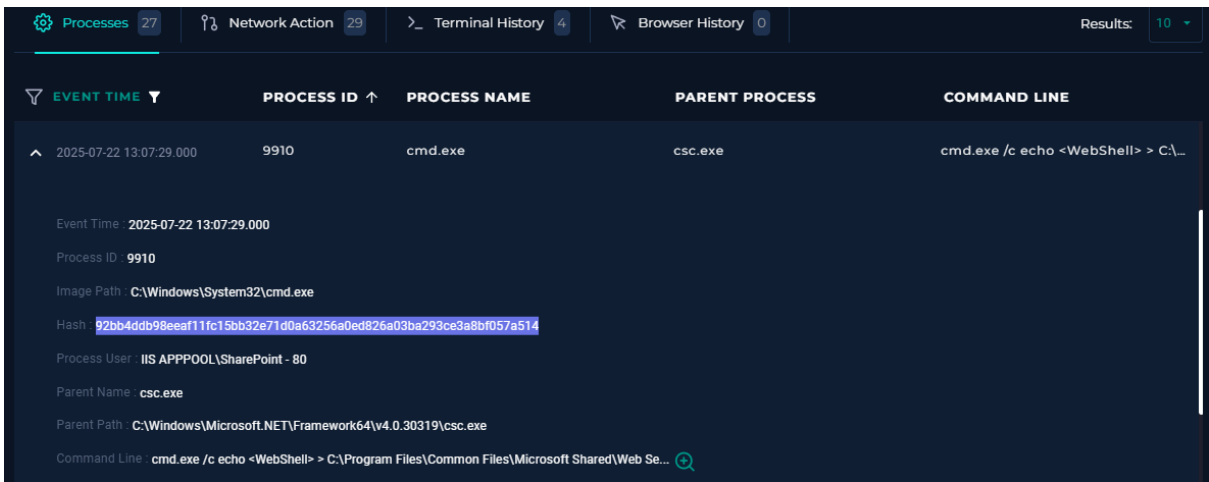


Figura 7: Hash del proceso detectado.

La validación del hash en VirusTotal confirmó la naturaleza maliciosa del proceso y su correspondencia con patrones de ataque ya conocidos.

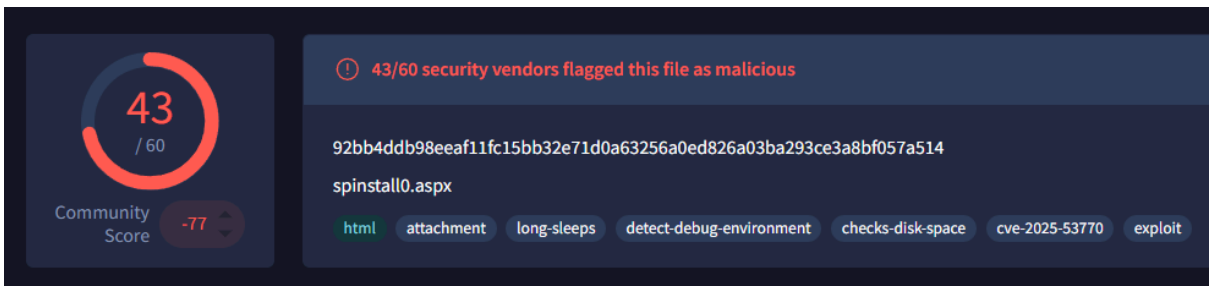


Figura 8: Confirmación de hash malicioso en VirusTotal.

Finalmente, la consulta en fuentes abiertas permitió identificar spinstall0.aspx como el WebShell utilizado, lo cual certifica la explotación exitosa de la vulnerabilidad en el servidor SharePoint.

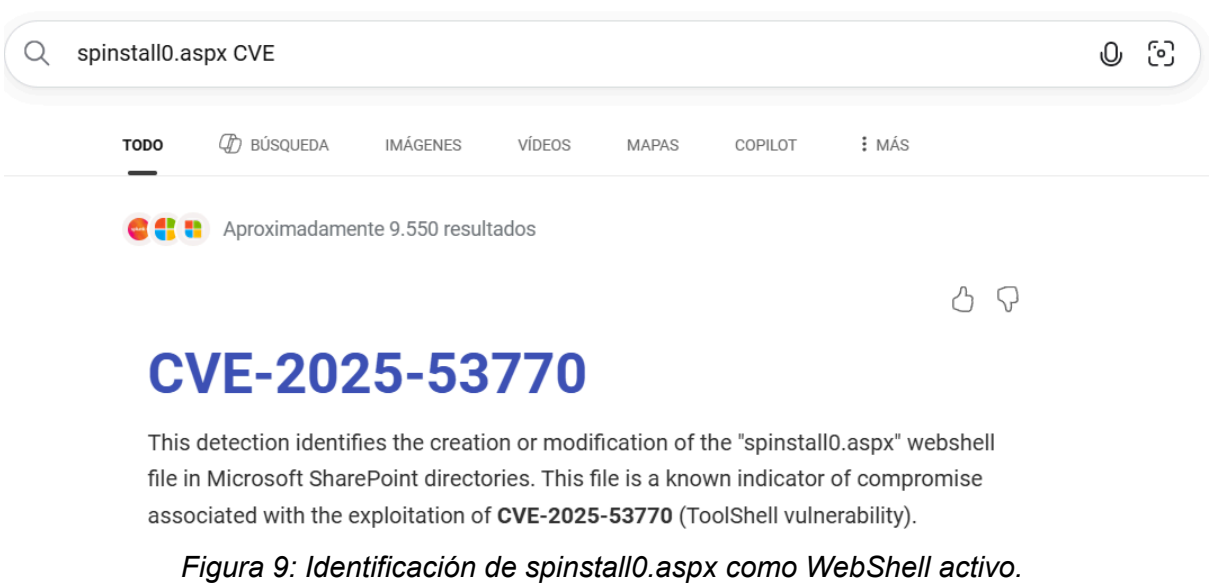


Figura 9: Identificación de spinstall0.aspx como WebShell activo.

4. Veredicto y Contención

- **Veredicto Final:** Verdadero Positivo
- **Acciones de Mitigación Tomadas:** Se confirmó la ejecución exitosa del ataque, logrando la inyección de RCE mediante payloads en Base64 que evadieron los controles de seguridad. Como respuesta inmediata, se procedió al aislamiento del endpoint afectado y se escaló el incidente al equipo de Nivel 2 (L2) para su resolución urgente.
- **Notas Adicionales / Recomendaciones:** Se recomienda investigar exhaustivamente el alcance del compromiso, evaluando el impacto de la ejecución del malware y la posible filtración de datos. Es imperativo bloquear la dirección IP de origen y las asociadas, además de proceder con el parcheo inmediato de la vulnerabilidad en el servidor afectado.